



INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

Course: BVWS103-OWASP Top 10 Vulnerabilities And
Exploitation Techniques(Sensitive Data Exposure)

Student Name: Abubakari-Sadique Hamidu

Student ID: 2025/FWSD/11392

Instructor: Aminu Iddris (CCNA, CompTIA, CEH, OSCP, CISSP,
CISM)

Lab 8: Sensitive Data Exposure

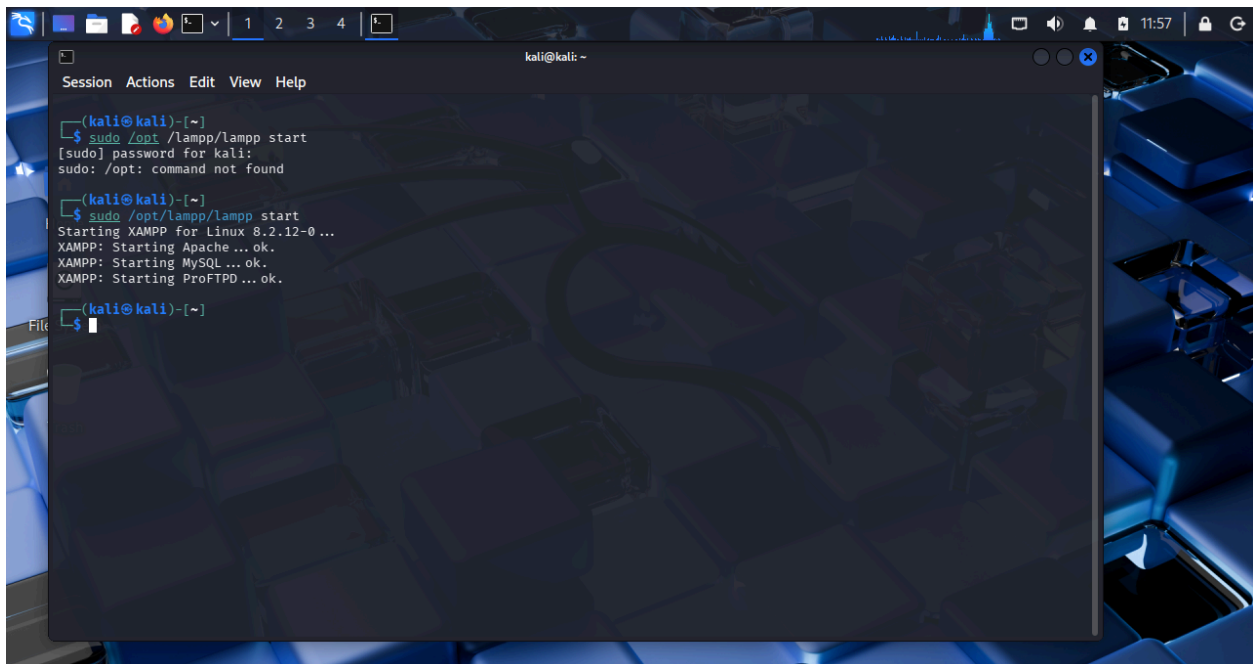
Objective

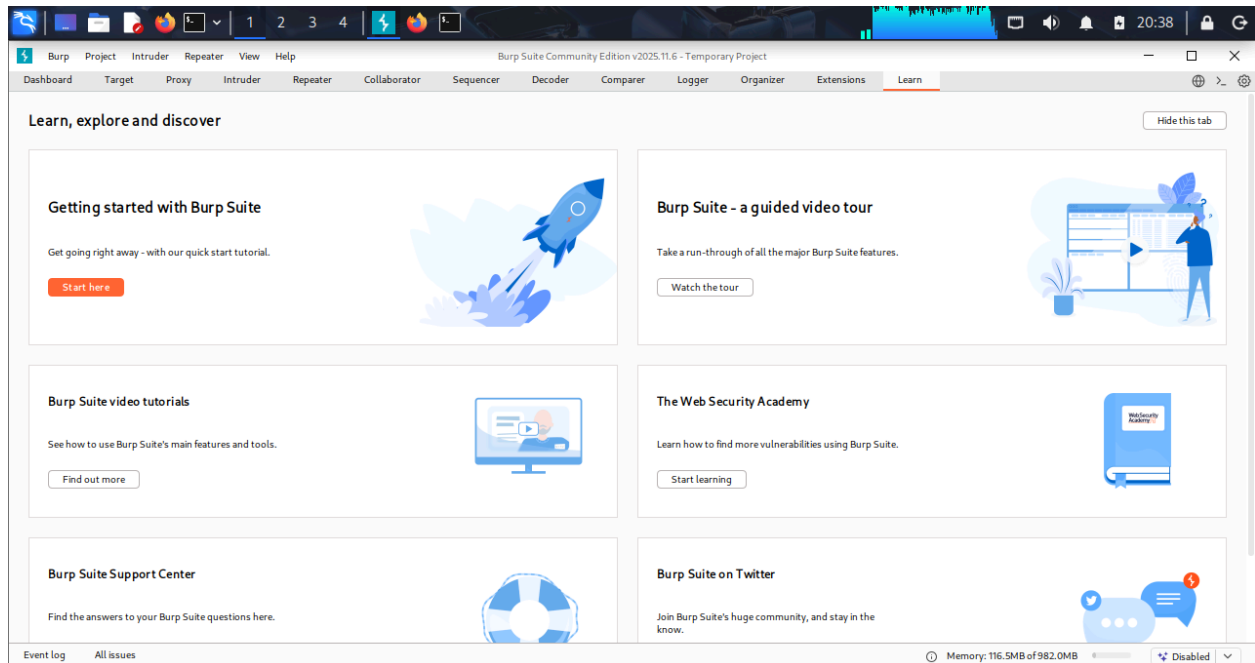
The purpose of this lab was to understand how sensitive data can be exposed when insecure transmission and storage methods are used, and how such vulnerabilities can be mitigated using HTTPS and secure password handling techniques. Burp Suite was used to demonstrate how attackers can intercept sensitive information and to verify the effectiveness of the mitigation steps.

Environment and Tools Used

- Operating System: Linux
- Web Server: Apache (LAMP/PP)
- Programming Language: PHP
- Interception Tool: Burp Suite
- Browser: Burp Suite built-in browser

Note: A Burp Suite CA certificate had already been installed and trusted on my system prior to this lab, which made HTTPS interception and access straightforward.





Task 1: Exploiting Sensitive Data Exposure

Vulnerable Application Setup

A vulnerable login application was created using:

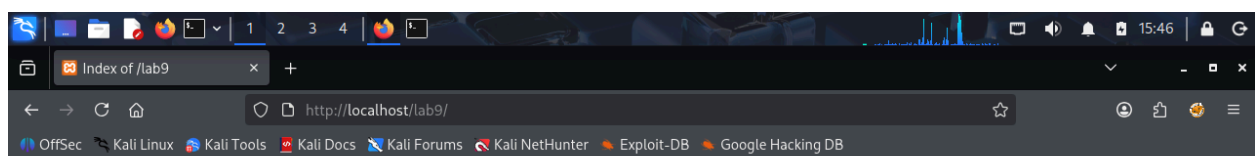
- `login.html`
- `Process_login.php`
- Inside a folder labeled `lab9`

The application transmitted login credentials over HTTP and stored passwords in plain text, making it vulnerable to sensitive data exposure.

```
root@kali: /opt/lampp/htdocs/lab9
Session Actions Edit View Help
(root@kali) - [/opt/lampp/htdocs/lab9]
# ls
login.html process_login.php
(root@kali) - [/opt/lampp/htdocs/lab9]
# 
The requested URL was not found on this server. If you entered the URL manually please check your spelling and try again.
If you think this is a server error, please contact the webmaster.

Error 404

localhost
Apache/2.4.58 (Ubuntu) OpenSSL/1.1.1w PHP/7.2.12 mod_perl/2.0.12 Perl/v5.34.1
```



Index of /lab9

Name	Last modified	Size	Description
Parent Directory	-	-	-
login.html	2026-02-08 13:57	659	
process_login.php	2026-02-08 13:59	599	

Exploitation Using Burp Suite

Burp Suite was configured with interception enabled. When the login form was submitted using valid credentials, Burp successfully intercepted the HTTP POST request.

The intercepted request clearly showed the username and password in plain text, confirming that sensitive data was exposed during transmission.

Request to https://www.google.com:443 [142.251.216.100]

Time	Type	Direction	Method	URL	Status code	Length
17:16:01.8 Fe...	HTTP	→ Request	GET	https://www.google.com/warmup.html		

Request

Pretty Raw Hex

```
1 GET /warmup.html HTTP/1.1
2 Host: www.google.com
3 Sec-Ch-Ua: "Chromium";v="143", "Not A(Brand";v="24"
4 Sec-Ch-Ua-Mobile: ?0
5 Sec-Ch-Ua-Platform: "Linux"
6 Accept-Language: en-US,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36
9 Sec-Purpose: prefetch;prerender
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 X-Client-Data: CNxiyGE=
12
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 0

Request cookies 0

Request headers 17

Event log (2) All issues

Memory: 116.3MB of 982.0MB

Request to https://www.google.com:443 [142.251.216.100]

Time	Type	Direction	Method	URL	Status code	Length
17:16:01.8 Fe...	HTTP	→ Request	GET	https://www.google.com/warmup.html		
17:18:59.8 Fe...	HTTP	→ Request	GET	https://www.google.com/warmup.html		
17:19:58.8 Fe...	HTTP	→ Request	GET	http://localhost/lab9/login.html		
17:20:21.8 Fe...	HTTP	→ Request	GET	http://localhost/lab9/login.html		

Request

Pretty Raw Hex

```
1 GET /warmup.html HTTP/1.1
2 Host: www.google.com
3 Sec-Ch-Ua: "Chromium";v="143", "Not A(Brand";v="24"
4 Sec-Ch-Ua-Mobile: ?0
5 Sec-Ch-Ua-Platform: "Linux"
6 Accept-Language: en-US,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36
9 Sec-Purpose: prefetch;prerender
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 X-Client-Data: CNxiyGE=
12
```

Inspector

Request attributes 2

Request query parameters 0

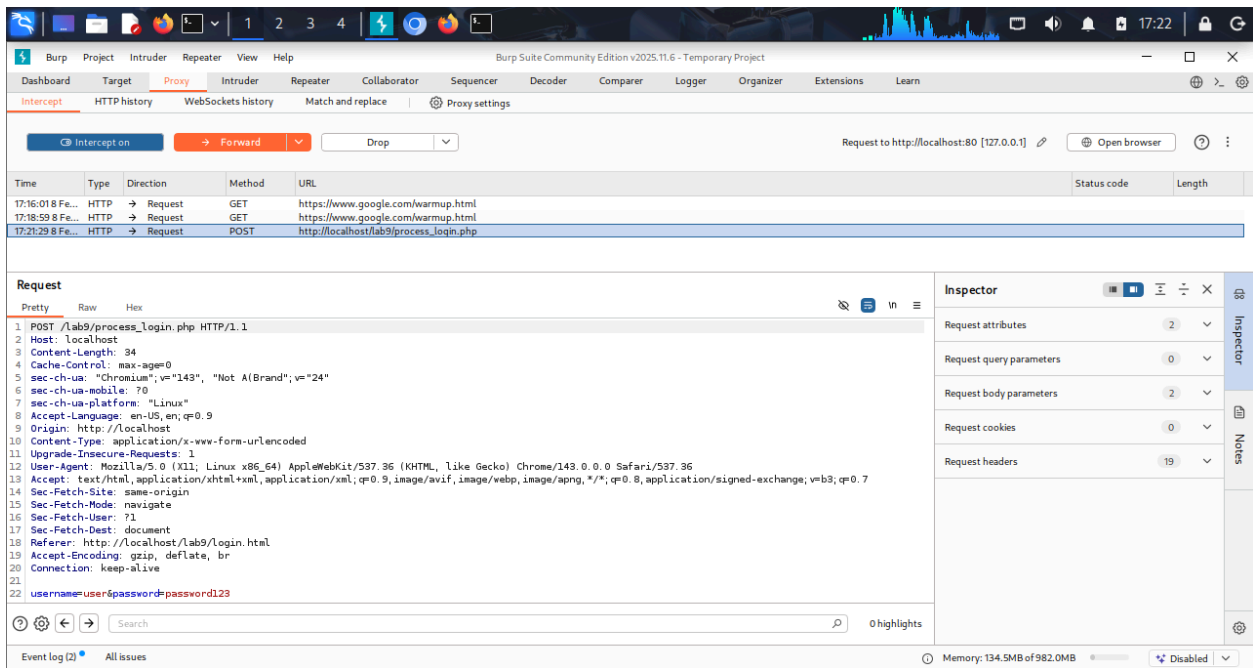
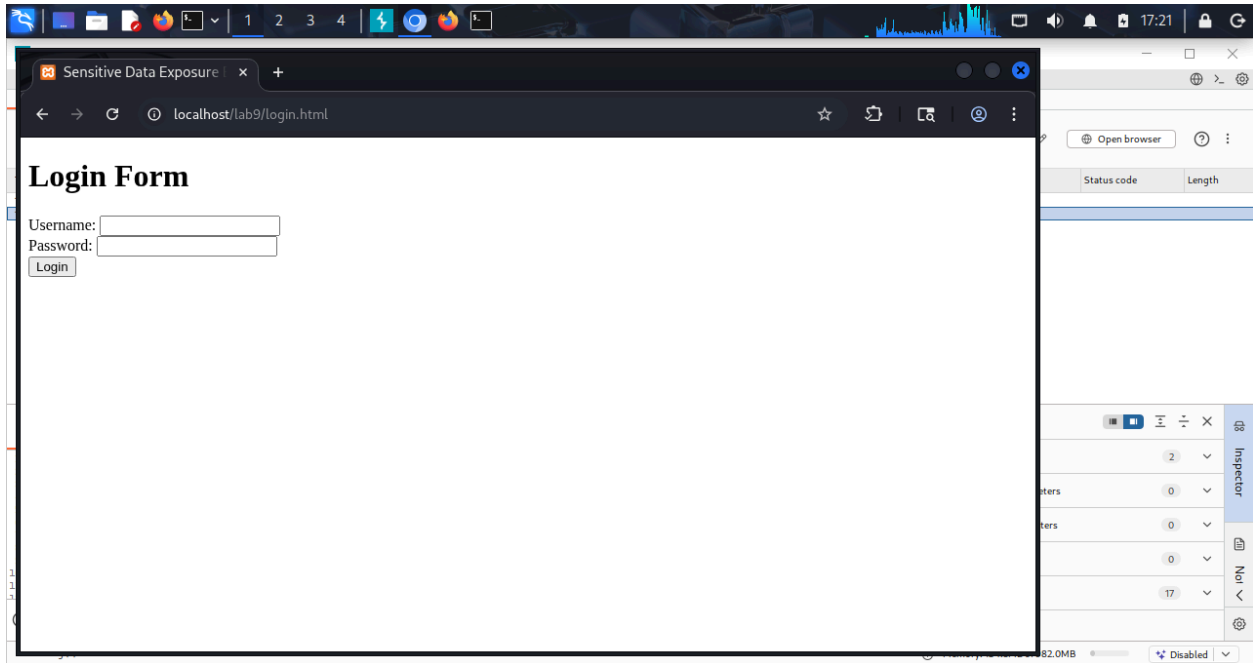
Request body parameters 0

Request cookies 0

Request headers 17

Event log (2) All issues

Memory: 136.5MB of 982.0MB



Request to http://localhost:80 [127.0.0.1]

Time	Type	Direction	Method	URL	Status code	Length
17:16:01.8 Fe...	HTTP	→ Request	GET	https://www.google.com/warmup.html		
17:18:59.8 Fe...	HTTP	→ Request	GET	https://www.google.com/warmup.html		
17:21:29.8 Fe...	HTTP	→ Request	POST	http://localhost/lab9/process_login.php		
17:34:58.8 Fe...	HTTP	→ Request	GET	http://detectportal.firefox.com/success.txt?pv4		
17:34:58.8 Fe...	HTTP	→ Request	GET	http://detectportal.firefox.com/success.txt?pv6		

Request

1 POST /lab9/process_login.php HTTP/1.1
2 Host: localhost
3 Content-Length: 34
4 Cache-Control: max-age=0
5 sec-ch-ua: "Chromium",v="143", "Not A(Brand";v="24"
6 sec-ch-ua-mobile: ?0
7 sec-ch-ua-platform: "Linux"
8 Accept-Language: en-US,en;q=0.9
9 Origin: http://localhost
10 Content-Type: application/x-www-form-urlencoded
11 Upgrade-Insecure-Requests: 1
12 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36
13 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-User: ?1
17 Sec-Fetch-Dest: document
18 Referer: http://localhost/lab9/login.html
19 Accept-Encoding: gzip, deflate, br
20 Connection: keep-alive
21
22 username=user&password=password123

Inspector

Request attributes

Protocol: HTTP/1.1

Name	Value
Method	POST
Path	/lab9/process_login.php

Request query parameters: 0
Request body parameters: 2
Request cookies: 0
Request headers: 19

Request to http://localhost:80 [127.0.0.1]

Time	Type	Direction	Method	URL	Status code	Length
17:16:01.8 Fe...	HTTP	→ Request	GET	https://www.google.com/warmup.html		
17:18:59.8 Fe...	HTTP	→ Request	GET	https://www.google.com/warmup.html		
17:21:29.8 Fe...	HTTP	→ Request	POST	http://localhost/lab9/process_login.php		
17:34:58.8 Fe...	HTTP	→ Request	GET	http://detectportal.firefox.com/success.txt?pv4		
17:34:58.8 Fe...	HTTP	→ Request	GET	http://detectportal.firefox.com/success.txt?pv6		

Request

1 POST /lab9/process_login.php HTTP/1.1
2 Host: localhost
3 Content-Length: 34
4 Cache-Control: max-age=0
5 sec-ch-ua: "Chromium",v="143", "Not A(Brand";v="24"
6 sec-ch-ua-mobile: ?0
7 sec-ch-ua-platform: "Linux"
8 Accept-Language: en-US,en;q=0.9
9 Origin: http://localhost
10 Content-Type: application/x-www-form-urlencoded
11 Upgrade-Insecure-Requests: 1
12 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36
13 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-User: ?1
17 Sec-Fetch-Dest: document
18 Referer: http://localhost/lab9/login.html
19 Accept-Encoding: gzip, deflate, br

Inspector

Request headers

Name	Value
Host	localhost
Content-Length	34
Cache-Control	max-age=0
sec-ch-ua	"Chromium",v="143", "Not A(Brand";v="24"
sec-ch-ua-mobile	?0
sec-ch-ua-platform	"Linux"
Accept-Language	en-US,en;q=0.9
Origin	http://localhost
Content-Type	application/x-www-form-urlencoded
Upgrade-Insecure-Requests	1
User-Agent	Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like ...
Accept	text/html,application/xhtml+xml,application/xml;q=0.9,image/aw...
Sec-Fetch-Site	same-origin
Sec-Fetch-Mode	navigate

Task 2: Mitigating Sensitive Data Exposure

1. Secure Transmission Using HTTPS

To mitigate the vulnerability, the login form was modified to submit data using HTTPS:

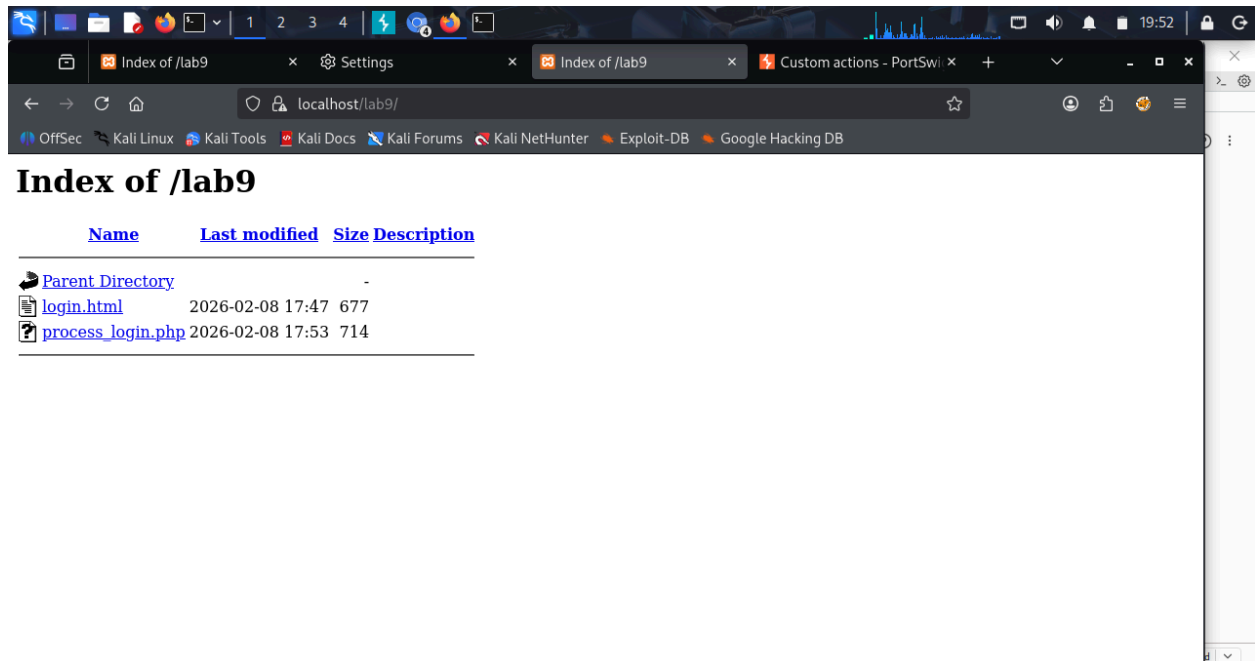
```
<form action="https://localhost/process_login.php" method="post">
```

HTTPS encrypts data in transit using SSL/TLS, preventing attackers from reading intercepted traffic.

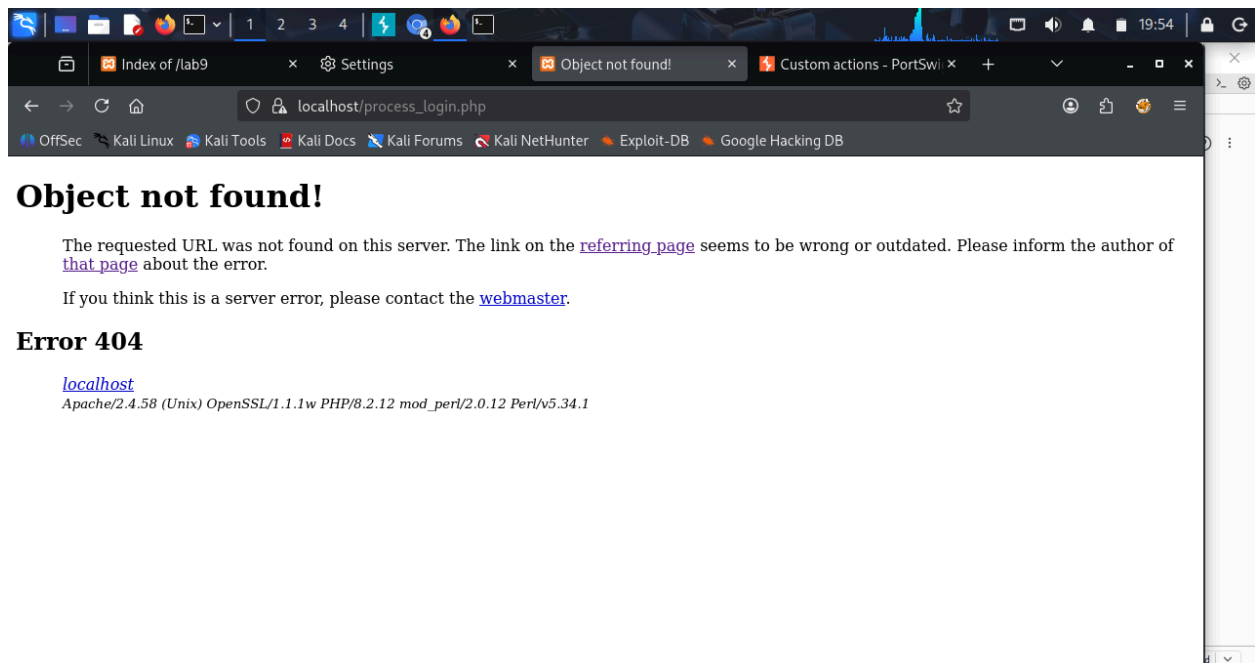
I was able to successfully access:

<https://localhost/lab6>

However, when attempting to navigate directly to [login.html](#), the browser returned an “**Object Not Found**” error. This issue will be fixed later.

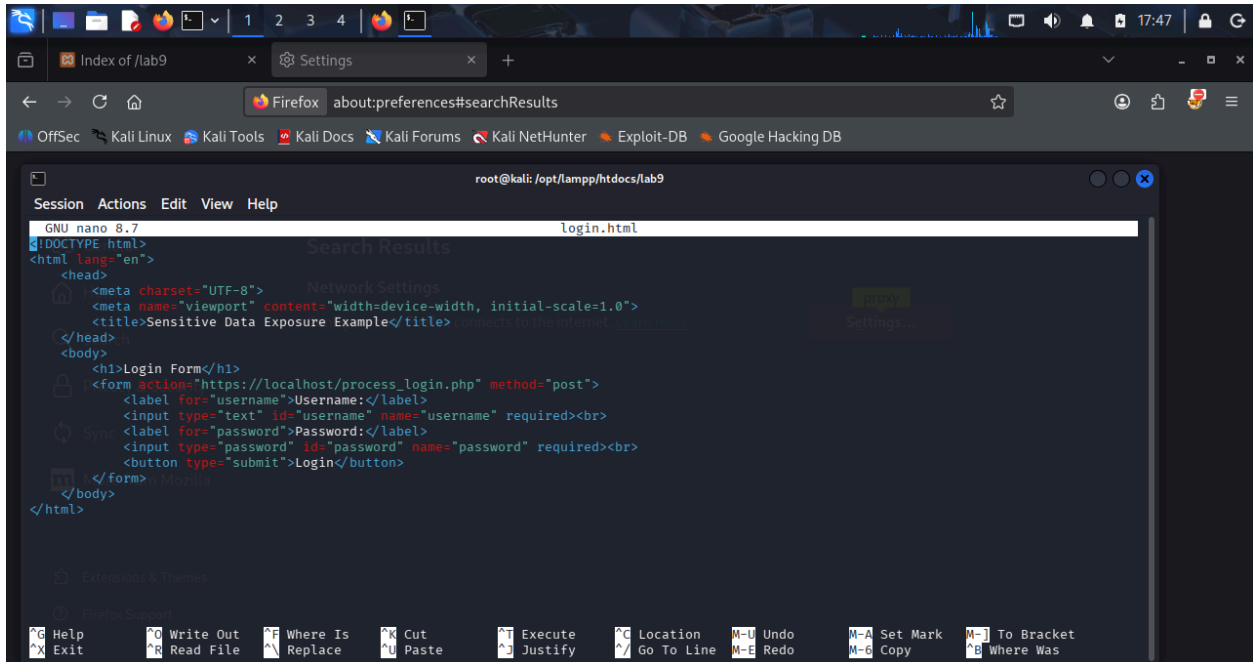


1

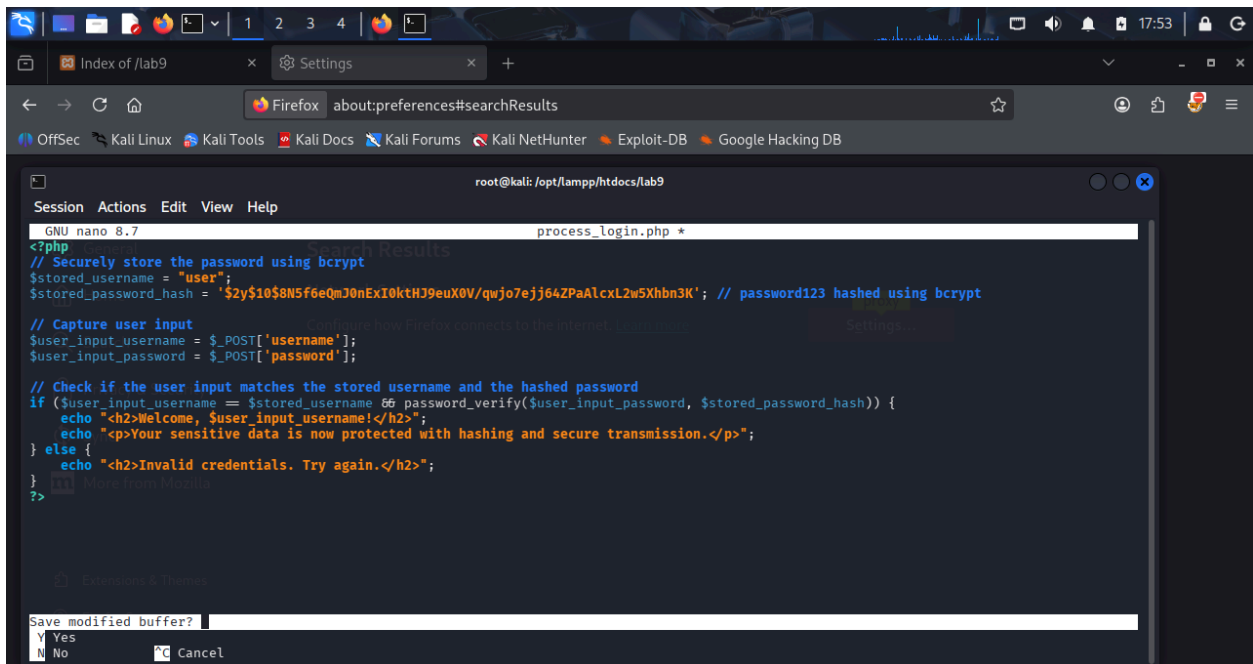


2. Secure Password Storage Using Hashing

The PHP login logic was updated to use `password_hash()` and `password_verify()` instead of storing passwords in plain text. This ensures that even if stored credentials are accessed, the original password cannot be easily recovered.



```
GNU nano 8.7 login.html
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Sensitive Data Exposure Example</title>
</head>
<body>
  <h1>Login Form</h1>
  <form action="https://localhost/process_login.php" method="post">
    <label for="username">Username:</label>
    <input type="text" id="username" name="username" required><br>
    <label for="password">Password:</label>
    <input type="password" id="password" name="password" required><br>
    <button type="submit">Login</button>
  </form>
</body>
</html>
```



```
GNU nano 8.7 process_login.php *
<?php
// Securely store the password using bcrypt
$stored_username = "user";
$stored_password_hash = '$2y$10$8N5f6eQmJ0nExI0ktHJ9euX0V/qwjo7ejj64ZPaAlcxL2w5Xhbn3K'; // password123 hashed using bcrypt

// Capture user input
$user_input_username = $_POST['username'];
$user_input_password = $_POST['password'];

// Check if the user input matches the stored username and the hashed password
if ($user_input_username == $stored_username && password_verify($user_input_password, $stored_password_hash)) {
  echo "<h2>Welcome, $user_input_username!</h2>";
  echo "<p>Your sensitive data is now protected with hashing and secure transmission.</p>";
} else {
  echo "<h2>Invalid credentials. Try again.</h2>";
}
?>
```

Save modified buffer? [Y] Yes [N] No [C] Cancel

Challenges Encountered

One major challenge encountered during this lab was related to file placement. Initially, the files were mistakenly created in:

/opt/htdocs

instead of the correct directory:

/opt/lampp/htdocs

This caused repeated **“Object Not Found”** errors when accessing the application through the browser, which was frustrating and time-consuming. After carefully reviewing the Apache document root and relocating the files to the correct directory, the issue was resolved.

Reflection

This lab clearly demonstrated how easily sensitive data can be exposed when HTTP and plaintext password storage are used. Using Burp Suite made the risk very visible, as credentials could be intercepted with minimal effort.

Implementing HTTPS and password hashing significantly improved the security of the application by protecting data both in transit and at rest. Although some configuration challenges were encountered, resolving them improved my understanding of server structure, SSL usage, and secure web application practices.

Conclusion

Sensitive data exposure is a serious security risk that can lead to credential theft and unauthorized access. This lab showed both how attackers exploit such vulnerabilities and how simple but effective measures like HTTPS and password hashing can mitigate them. Secure configuration and attention to deployment details are essential for building trustworthy applications.